

****SharePoint ransomware hit the grid**** Warlock weaponized a known SharePoint flaw to cripple utilities in three Iberian nations within 48 hours. Are we still waiting for DevSecOps to catch up before the next supply-chain breach?

SHIFT-LEFT CAREER MAP • Master **CISSP** or **CISM** and **Secure DevOps Engineer** (AWS/Azure) – validates code and governance protection. • Add **GIAC Secure Software Programmer (GSSP)** to embed security controls at the IDE level. • Earn **Microsoft Certified: Security, Compliance, and Identity Fundamentals** – speak the language of the SharePoint stack Warlock abuses.

****⚠ TECHNICAL RADIANCE**** Warlock's campaign hinged on exploiting ****CVE-2025-XXXX**** (unpatched SharePoint Remote Code Execution) and then disabling endpoint AV via a custom ****PowerShell**** payload. The dropper for the macOS fake-Zoom installer carried a ****756 KB**** Mach-O binary that unpacked at runtime, showing attackers still favor "small-footprint" weapons.

**** [HARD] KEY CERTIFICATIONS FOR SHIFT-LEFT**** - ****CompTIA Security+**** – baseline for any SOC analyst pivoting to DevSecOps. - ****Certified Cloud Security Professional (CCSP)**** – required to secure SaaS platforms like SharePoint Online. - ****Offensive Security Certified Professional (OSCP)**** – forces you to think like Warlock's red-team, essential for early SDLC threat-modeling.

**** [NO GRAPH] CONTRAST FRAMEWORK**** What most teams assume: "If we patch SharePoint after a breach, we're safe." What actually happens: Attackers use unpatched libraries *and* mis-configured permissions to bypass patches, then move laterally with stolen service accounts. The gap is not a missing patch; it's a missing ****shift-left**** mindset.

****[NO GUESS] PRACTITIONER MICRO-STORY**** Last week our CI pipeline flagged a ****CVE-2024-3115**** in a third-party component. I pushed the fix through ****GitHub Advanced Security****. The automated ****SOAR**** playbook rolled out the remediation across 12 micro-services before any alert hit the SIEM. The same process would have bought us hours, not days, against a Warlock-style attack.

OPERATIONAL CHECKLIST

- Integrate **SBOM** generation into every build.
- Enforce **static analysis** (SAST) with a "fail-fast" policy.
- Deploy **runtime application self-protection (RASP)** on all SharePoint sites.
- Schedule **weekly credential-hygiene scans** for service accounts.
- Tie **security tickets** to **Jira** so developers own remediation.

**** NO GLYPH POWER CLOSING**** **In 12 months, any organization that still treats patching as a post-breach step will be forced off the grid.**